

NETWORK SECURITY EVALUATION

VPN Segmentation and Identity Policy Review

Prepared by: Rona Playda

Environment: Controlled GNS3 virtual network simulation

Assessment scope: Remote-access segmentation, firewall policy, and Active Directory password controls

Tools: GNS3, OPNsense, Windows PowerShell, ICMP, and TCP connectivity testing

Date analyzed: August 5, 2026

Portfolio notice: This case study was completed in a controlled virtual lab. All addresses shown are non-routable RFC1918 lab addresses. Course identifiers, assignment language, document metadata, and potentially identifying command-prompt paths were removed.

Executive Summary

This assessment evaluated two security weaknesses in a simulated enterprise network: excessive reachability from a remote-access segment and inconsistent Active Directory password controls. Connectivity tests, OPNsense firewall review, and PowerShell policy queries showed that the VPN interface accepted all IPv4 traffic and that several human or administrator accounts were exempt from password expiration.

The evidence confirmed network-layer reachability from the Remote Access PC to an internal IT workstation, but it did not confirm RDP or SMB service access. The assessment also found a seven-character minimum password length, no account-lockout threshold, and multiple PasswordNeverExpires exceptions. The recommended remediation applies least privilege, destination- and service-specific rules, improved monitoring, stronger authentication controls, and formal exception review.

Risk statement: A compromised remote-access endpoint could perform internal discovery or attempt lateral movement, while long-lived credentials and unlimited authentication attempts increase password-guessing and password-spraying exposure.

1. Environment and Scope

Component	Lab role
Remote Access PC	VPN-connected administrative endpoint on 172.16.3.0/24
OPNsense firewall	Controls traffic entering through VPN interface em2 at 172.16.3.254
Remote Admin server	Designated server on 172.16.2.0/24
Department networks	IT, Academic Affairs, Professor, and other internal segments

Active Directory	Central identity service and domain password policy
------------------	---

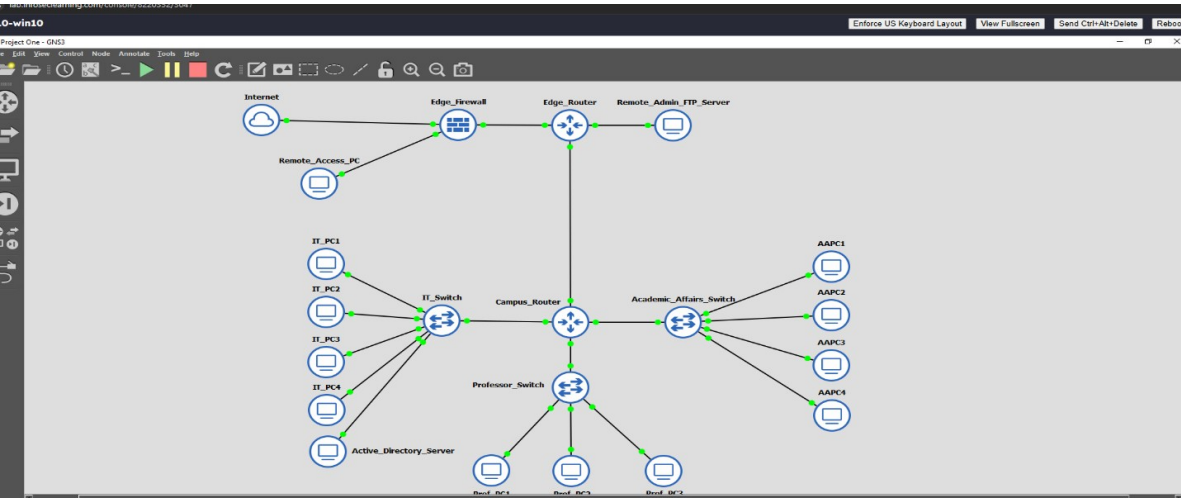


Figure 1. Controlled GNS3 topology used for the network evaluation.

2. Finding One — Excessive VPN Reachability

Observed behavior

The Remote Access PC used 172.16.3.1/24 with default gateway 172.16.3.254. It received three ICMP replies from internal IT_PC1 at 192.168.10.1, even though that workstation was not the designated remote-administration destination. AAPC1 at 192.168.30.1 did not reply. TCP tests to IT_PC1 on RDP port 3389 and SMB port 445 failed.

Evidence boundary: The tests confirm unnecessary network-layer reachability to one internal workstation. They do not prove successful login, RDP access, SMB access, or unrestricted reachability to every internal subnet.

Root cause

The active OPNsense rule pass in quick on em2 inet all permits all IPv4 traffic entering the VPN interface without source, destination, protocol, or service restrictions. Because quick stops further rule evaluation after a match, the rule bypasses more restrictive downstream evaluation and violates least privilege.

Recommended control

- Back up the firewall configuration and confirm the legitimate remote-access business requirement.
- Replace the allow-all rule with a source-, destination-, protocol-, and port-specific rule.
- Permit the remote endpoint to reach only the designated administration server over approved encrypted services.
- Place explicit deny-and-log rules for unauthorized internal networks after the required allow rule.
- Retest ICMP and approved TCP services, then review OPNsense logs for denied scans or repeated connection attempts.

3. Finding Two — Weak Identity and Password Controls

Observed behavior

The default domain policy enabled complexity, disabled reversible encryption, retained 24 passwords, and set a 42-day maximum age. However, the minimum length was seven characters and LockoutThreshold was zero, allowing unlimited failed attempts. Administrator, ITAdmin, and ITPC1 through ITPC4 also had PasswordNeverExpires set to True.

Risk

Account-level expiration exceptions override the domain expiration setting. Long-lived credentials, a short minimum length, and unlimited attempts increase exposure to password guessing, reuse, and spraying. The underlying control problem is inconsistent account provisioning and inadequate review of security-sensitive flags.

Recommended control

- Inventory every PasswordNeverExpires account and document its owner and business justification.
- Remove the exception from human and administrative accounts; use managed service accounts or controlled rotation for service identities.
- Require at least 14 characters and encourage unique passphrases; block common or compromised passwords.
- Require MFA for administrators and remote access.
- Configure a reasonable lockout or smart-lockout threshold and alert on password-spraying patterns.
- Change passwords when compromise is suspected; do not rely on routine expiration as a substitute for strong passwords and MFA.
- Pilot changes with a nonprivileged account, communicate with users, and audit exceptions periodically.

4. Validation Results

Test	Result	Interpretation
Remote PC to designated server: ICMP/TCP 21	Failed	Expected service was not reachable during testing
Remote PC to IT_PC1: ICMP	Succeeded	Unnecessary network-layer reachability confirmed
Remote PC to IT_PC1: TCP 3389	Failed	RDP service access not established
Remote PC to IT_PC1: TCP 445	Failed	SMB service access not established
Remote PC to AAPC1: ICMP	Failed	No reachability confirmed to this destination

5. Final Assessment

The evaluation confirmed an overly broad VPN firewall rule and inconsistent account-level password settings. Destination- and service-specific access controls will isolate the remote-access segment, while removal of unjustified exceptions, stronger password requirements, MFA, monitoring, and controlled logout protections will reduce credential risk without preventing legitimate work.

Area	Assessment
VPN segmentation	Needs remediation — allow-all rule violates least privilege
Service exposure	Not confirmed — tested RDP and SMB connections failed
Password policy	Needs improvement — seven-character minimum and no logout threshold
Account exceptions	Needs remediation — multiple PasswordNeverExpires flags
Overall priority	High for firewall rule correction; Medium-High for identity-policy remediation

Appendix A — Supporting Evidence

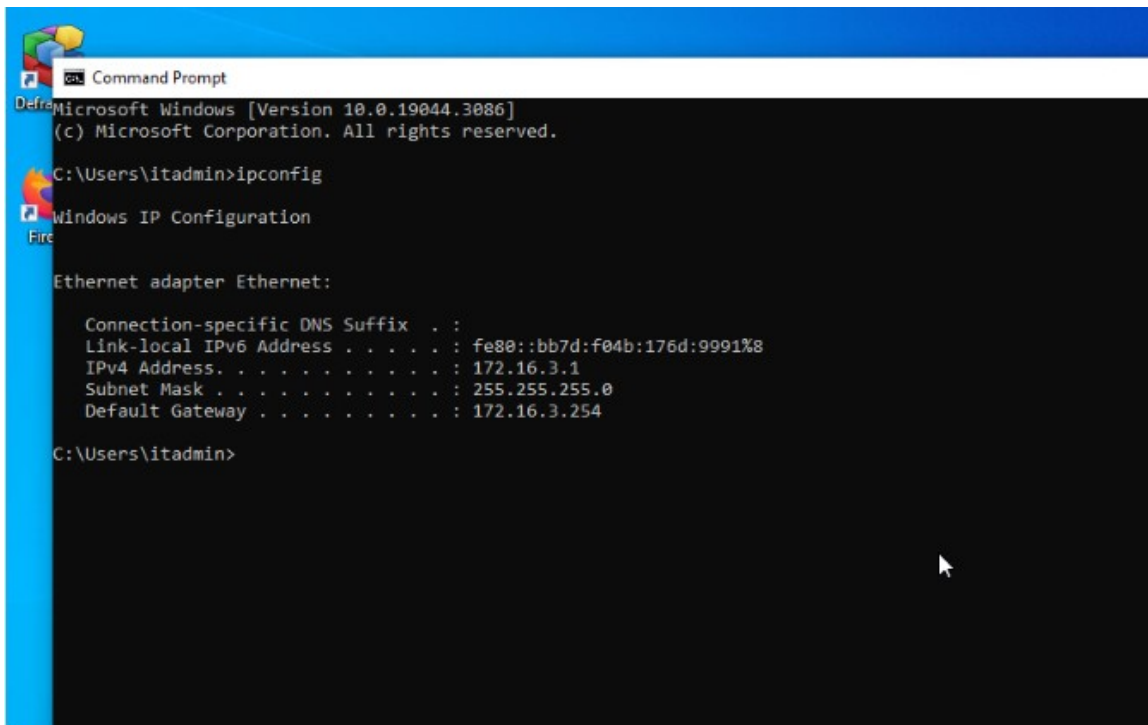


Figure 2. Remote Access PC configuration: 172.16.3.1/24 with gateway 172.16.3.254.

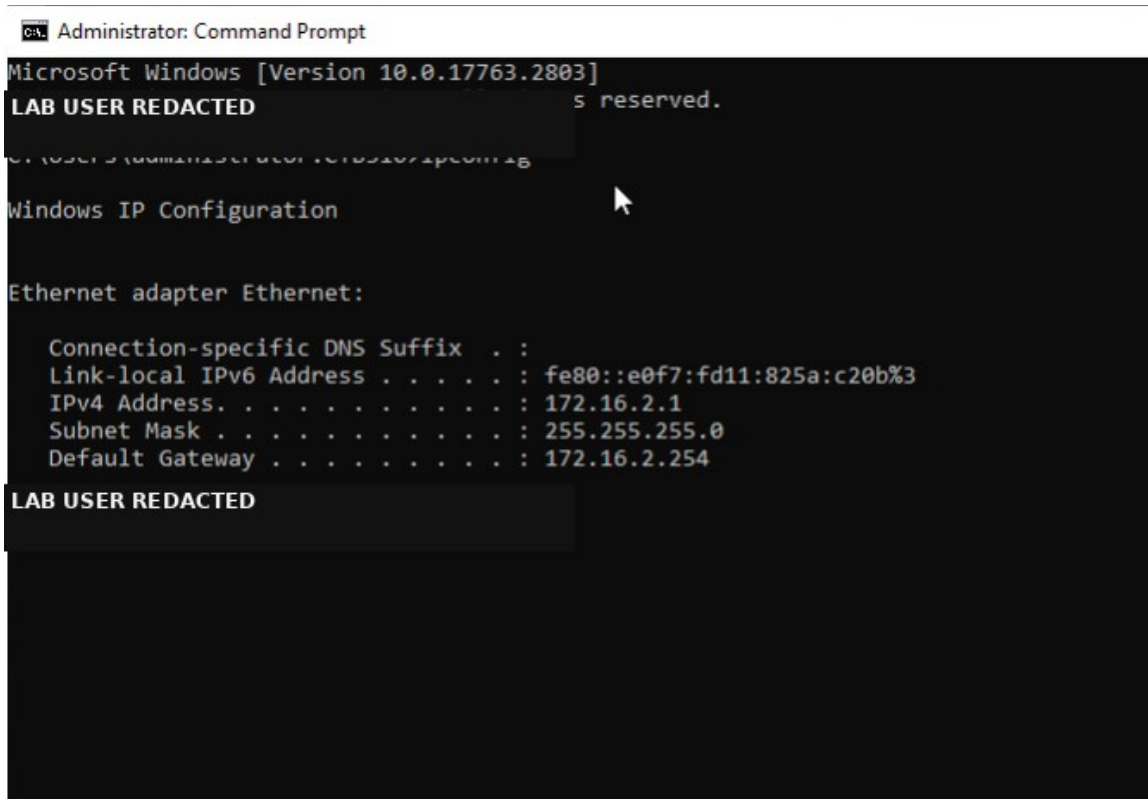
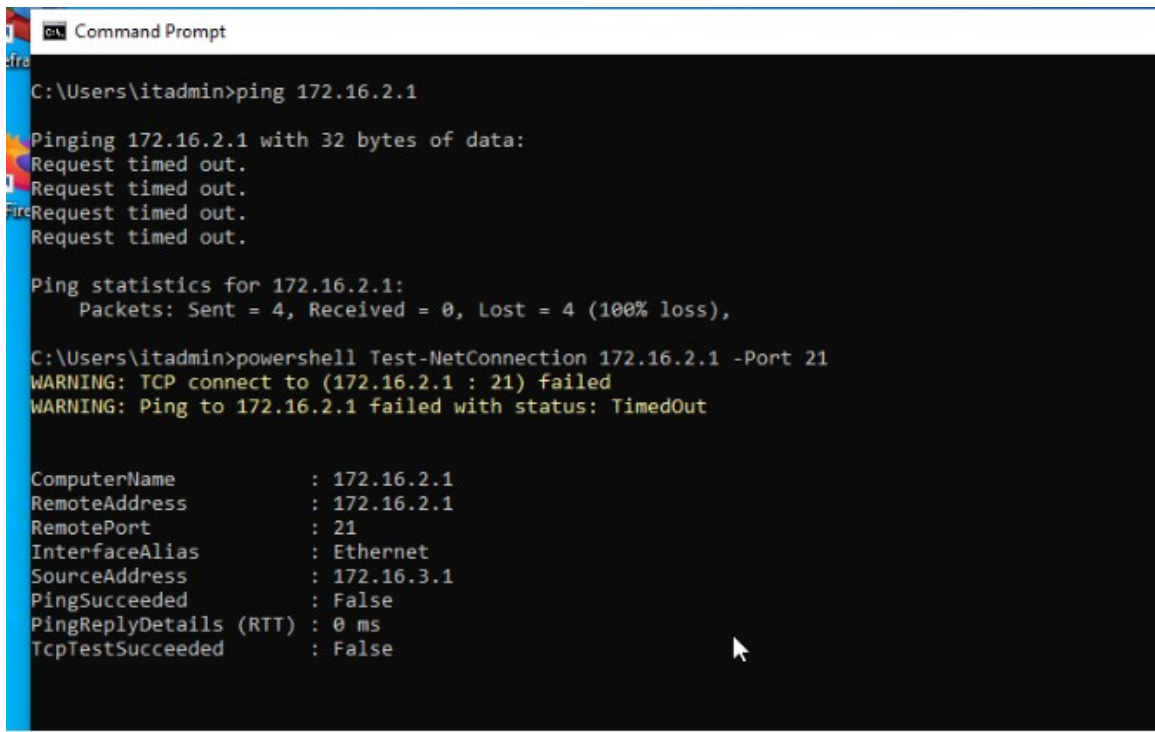


Figure 3. Remote Admin server configuration: 172.16.2.1/24 with gateway 172.16.2.254; command-prompt path sanitized.



```
Command Prompt
C:\Users\itadmin>ping 172.16.2.1

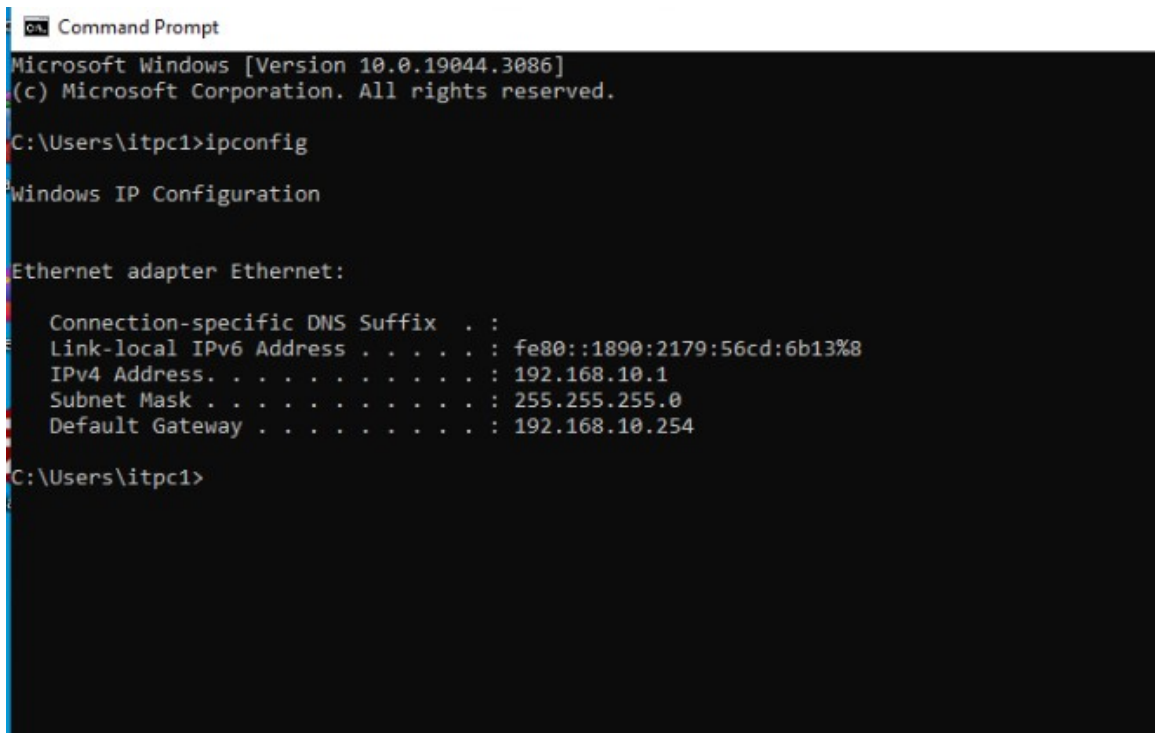
Pinging 172.16.2.1 with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 172.16.2.1:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\Users\itadmin>powershell Test-NetConnection 172.16.2.1 -Port 21
WARNING: TCP connect to (172.16.2.1 : 21) failed
WARNING: Ping to 172.16.2.1 failed with status: TimedOut

ComputerName           : 172.16.2.1
RemoteAddress          : 172.16.2.1
RemotePort             : 21
InterfaceAlias         : Ethernet
SourceAddress          : 172.16.3.1
PingSucceeded          : False
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded       : False
```

Figure 4. Failed ICMP and TCP port 21 tests from the remote endpoint to the designated server.



```
Command Prompt
Microsoft Windows [Version 10.0.19044.3086]
(c) Microsoft Corporation. All rights reserved.

C:\Users\itpc1>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::1890:2179:56cd:6b13%8
    IPv4 Address. . . . . : 192.168.10.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.10.254

C:\Users\itpc1>
```

Figure 5. IT_PC1 configuration on the internal 192.168.10.0/24 network.

```
C:\Users\itadmin>ping 192.168.10.1

Pinging 192.168.10.1 with 32 bytes of data:
Reply from 192.168.10.1: bytes=32 time=502ms TTL=125
Reply from 192.168.10.1: bytes=32 time=632ms TTL=125
Request timed out.
Reply from 192.168.10.1: bytes=32 time=191ms TTL=125

Ping statistics for 192.168.10.1:
    Packets: Sent = 4, Received = 3, Lost = 1 (25% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 191ms, Maximum = 632ms, Average = 441ms

C:\Users\itadmin>
```

Figure 6. Successful ICMP replies from IT_PC1 confirm network-layer reachability.

```
Command Prompt

C:\Users\itadmin>ping 192.168.10.1

Pinging 192.168.10.1 with 32 bytes of data:
Reply from 192.168.10.1: bytes=32 time=502ms TTL=125
Reply from 192.168.10.1: bytes=32 time=632ms TTL=125
Request timed out.
Reply from 192.168.10.1: bytes=32 time=191ms TTL=125

Ping statistics for 192.168.10.1:
    Packets: Sent = 4, Received = 3, Lost = 1 (25% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 191ms, Maximum = 632ms, Average = 441ms

C:\Users\itadmin>powershell Test-NetConnection 192.168.10.1 -Port 3389
WARNING: TCP connect to (192.168.10.1 : 3389) failed

ComputerName           : 192.168.10.1
RemoteAddress          : 192.168.10.1
RemotePort             : 3389
InterfaceAlias         : Ethernet
SourceAddress          : 172.16.3.1
PingSucceeded          : True
PingReplyDetails (RTT) : 270 ms
TcpTestSucceeded       : False

C:\Users\itadmin>
```

Figure 7. TCP port 3389 test failed; RDP service access was not established.


```
C:\Users\itadmin>powershell Test-NetConnection 192.168.10.1 -Port 445
WARNING: TCP connect to (192.168.10.1 : 445) failed

ComputerName           : 192.168.10.1
RemoteAddress          : 192.168.10.1
RemotePort             : 445
InterfaceAlias         : Ethernet
SourceAddress          : 172.16.3.1
PingSucceeded          : True
PingReplyDetails (RTT) : 3 ms
TcpTestSucceeded       : False

C:\Users\itadmin>
```

Figure 8. TCP port 445 test failed; SMB service access was not established.

```
Microsoft Windows [Version 10.0.19044.3086]
(c) Microsoft Corporation. All rights reserved.

C:\Users\AAPC1>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::c3fd:e36:ad91:a14b%8
    IPv4 Address. . . . . : 192.168.30.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.30.254

C:\Users\AAPC1>
```

Figure 9. AAPC1 configuration on the 192.168.30.0/24 network.

```

C:\Users\itadmin>ping 192.168.30.1

Pinging 192.168.30.1 with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 192.168.30.1:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\Users\itadmin>

```

Figure 10. ICMP requests to AAPC1 timed out; reachability was not confirmed.

```

| Website:      https://opnsense.org/      |      @00\\    ///000
| Handbook:    https://docs.opnsense.org/  |      )))))))  (((((((
| Forums:      https://forum.opnsense.org/ |      @00///    \\0000
| Code:        https://github.com/opnsense |      0000      0000
| Twitter:     https://twitter.com/opnsense |      0000000000000000
|-----|-----|-----|

*** OPNsense.localdomain: OPNsense 22.1.18_4 (amd64/OpenSSL) ***

LAN (em1)      -> v4: 10.10.10.254/24
VPN (em2)      -> v4: 172.16.3.254/24
WAN (em0)      -> v4/DHCP4: 192.168.122.126/24

HTTPS: SHA256 A3 00 A5 DD 91 05 F5 E4 5D 47 ED 1E A0 CF 17 55
              F7 90 26 FB 04 EF 7A 42 00 33 0E 41 2E 22 1E 92

0) Logout
1) Assign interfaces
2) Set interface IP address
3) Reset the root password
4) Reset to factory defaults
5) Power off system
6) Reboot system
7) Ping host
8) Shell
9) pfTop
10) Firewall log
11) Reload all services
12) Update from console
13) Restore a backup

Enter an option: █

```

Figure 11. OPNsense interface assignments showing VPN interface em2 at 172.16.3.254/24.

```

pass in log quick on em1 proto tcp from any to (self) port = https flags S/SA keep state label "fc644ddefed1dc33844f7142cb756947"
pass out log route-to (em0 192.168.122.1) inet from (em0) to ! (em0:network) flags S/SA keep state allow-opts label "49484b4b90e87d327815684798f010e9"
pass in quick on em0 reply-to (em0 192.168.122.1) inet proto icmp all keep state label "1f0c0f3d03b3d9912239e9235b97e1dc"
pass in quick on em1 inet from (em1:network) to any flags S/SA keep state label "c9fb95f8275a8a73ce4a68190ed7bc51"
pass in quick on em1 inet6 from (em1:network) to any flags S/SA keep state label "e0d7d87c02c29ff98108738507811fec"
pass in quick on em2 inet all flags S/SA keep state label "1559f5341e911c331104b75aab13e05e"
pass out log on em0 route-to (em0 192.168.122.1) inet proto udp from any to 172.16.3.1 port = isakmp keep state label "86ff73a32220ac78a833807211fb9d1d"
pass in log on em0 reply-to (em0 192.168.122.1) inet proto udp from 172.16.3.1 to any port = isakmp keep state label "becd42ad64f2cf8a0365778317979424"
pass out log on em0 route-to (em0 192.168.122.1) inet proto udp from any to 172.16.3.1 port = ipsec-nat-t keep state label "291d6271de7c91c60d719d7e04bf4f9a"
pass in log on em0 reply-to (em0 192.168.122.1) inet proto udp from 172.16.3.1 to any port = ipsec-nat-t keep state label "d0f9025578f17e73a9b37a812f7f31b2"
pass out log on em0 route-to (em0 192.168.122.1) inet proto esp from any to 172.16.3.1 keep state label "cdb6e8ea376b4be8803b82958dca045e"
pass in log on em0 reply-to (em0 192.168.122.1) inet proto esp from 172.16.3.1 to any keep state label "b6035e6620a458a88c19fadd8b95764a"
root@OPNsense:~ # █

```

Figure 12. Active OPNsense rules showing pass in quick on em2 inet all.

Command Prompt

```

Microsoft Windows [Version 10.0.17763.2803]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\itadmin>net accounts /domain
Force user logoff how long after time expires?:      Never
Minimum password age (days):                        1
Maximum password age (days):                        42
Minimum password length:                             7
Length of password history maintained:               24
Lockout threshold:                                   Never
Lockout duration (minutes):                          30
Lockout observation window (minutes):                30
Computer role:                                       PRIMARY
The command completed successfully.

C:\Users\itadmin>_

```

Figure 13. Domain policy summary showing minimum length seven and lockout threshold zero.

```

Computer role: PRIMARY
The command completed successfully.

C:\Users\itadmin>powershell -Command "Get-ADUser -Filter * -Properties PasswordNeverExpires | Select-Object Name, SamAccountName, PasswordNeverExpires"

Name                SamAccountName PasswordNeverExpires
----                -
Administrator      Administrator      True
Guest               Guest              False
krbtgt              krbtgt             True
ITPC1               ITPC1              True
ITPC2               ITPC2              True
ITPC3               ITPC3              True
ITPC4               ITPC4              True
PROFPC1             PROFPC1            True
PROFPC2             PROFPC2            True
PROFPC3             PROFPC3            True
AAPC1               AAPC1              True
AAPC2               AAPC2              True
AAPC3               AAPC3              True
AAPC4               AAPC4              True
A Admin             AAAdmin            True
Prof Admin          ProfAdmin           True
IT Admin            ITAdmin            True

C:\Users\itadmin>

```

Figure 14. PowerShell results showing multiple PasswordNeverExpires exceptions.

```

LAB USER REDACTED

C:\Users\itadmin>net-List ComplexityEnabled,MinPasswordLength,PasswordHistoryCount,MaxPasswordAge,LockoutThreshold,ReversibleEncryptionEnabled

ComplexityEnabled      : True
MinPasswordLength      : 7
PasswordHistoryCount    : 24
MaxPasswordAge         : 42.00:00:00
LockoutThreshold       : 0
ReversibleEncryptionEnabled : False

C:\Users\itadmin>
LAB USER REDACTED

```

Figure 15. Default domain password policy details; command-prompt path sanitized.

Appendix B — Portfolio Sanitization

Removed or reframed for public distribution: course code, project/assignment labels, interview framing, original document metadata, and command-prompt paths containing course-specific or potentially identifying lab-user information. The technical topology, RFC1918 addresses, firewall rules, commands, test results, and security conclusions were preserved.

This report documents a controlled simulation and does not represent a production customer assessment.